

**PRESENTED BY :**

Muhammad Hibatullah Wafi



JERSEYSEKAT  
WEB APPLICATION

# PENETRATION TESTING REPORT

# RINGKASAN EKSEKUTIF

## OBJECTIVE

PT Mini Bootcamp Sukses (MBS) melakukan Penetration Testing sesuai standar ISO 27001. Pengujian dilakukan dengan pendekatan Blackbox Testing untuk mensimulasikan serangan eksternal. Tim mengidentifikasi kerentanan melalui pemindaian otomatis dan analisis manual, lalu menilai risiko berdasarkan dampak dan kemungkinan eksploitasi. Seluruh hasil dirangkum dalam laporan ini.

## AREA, WAKTU DAN LINGKUNGAN

Kegiatan *Penetration Testing* dilakukan dari area eksternal dan berlangsung pada tanggal 16 November 2025 sampai dengan 18 November 2025 dan di lingkungan Production menggunakan akses jaringan internet.

# METODOLOGI

## BLACK BOX TESTING

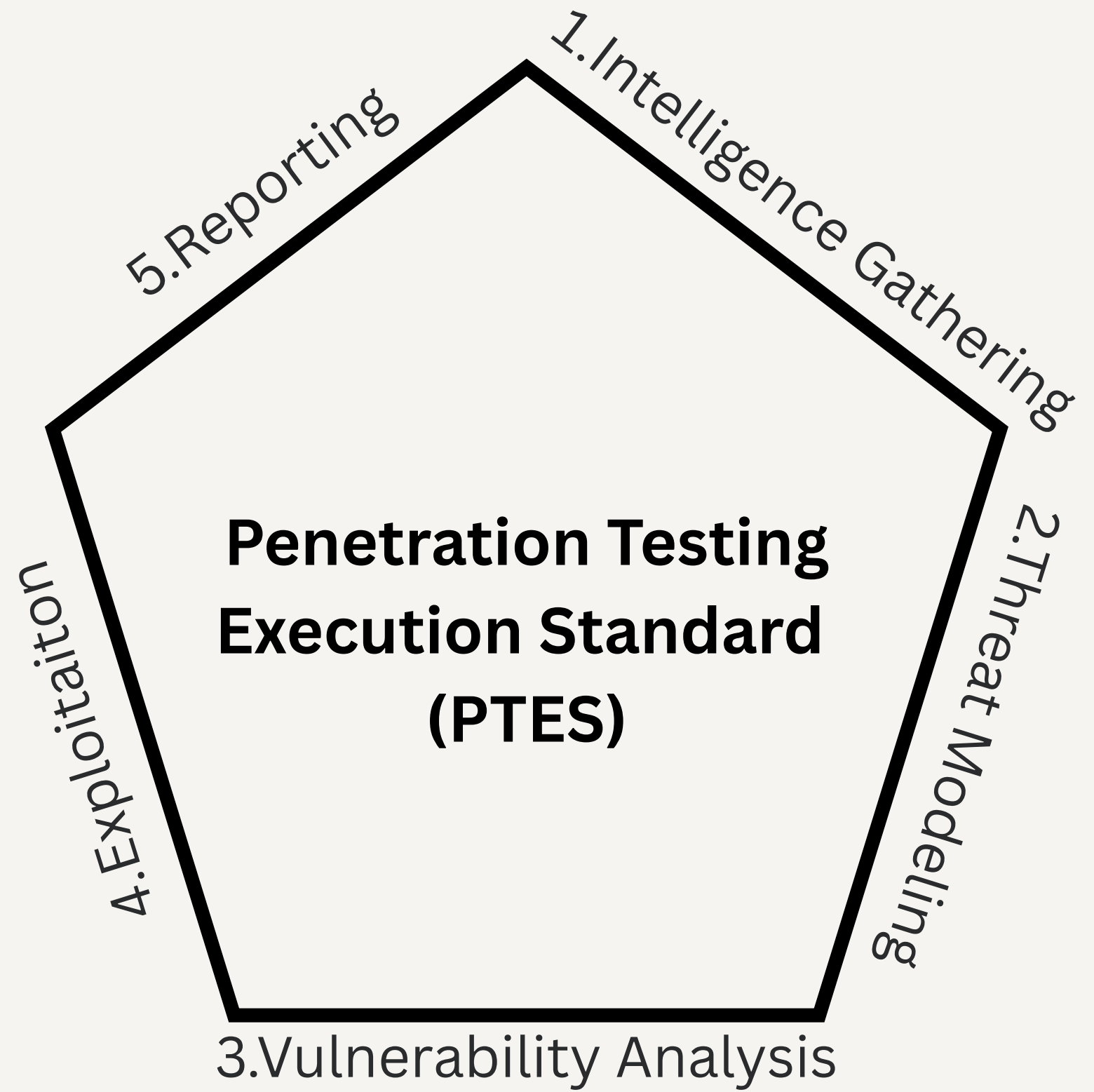
Penguji menilai keamanan tanpa mengetahui kredensial atau struktur internal sistem. Metode ini mensimulasikan serangan nyata dari sudut pandang pengguna eksternal untuk menemukan kerentanan melalui fungsi dan antarmuka aplikasi.

## PENILAIAN TINGKAT RESIKO

Penilaian tingkat risiko dan dampak dari kerentanan keamanan yang ditemukan dalam sistem perbankan diukur dengan menggunakan CVSS (Common Vulnerability Scoring System). CVSS merupakan sistem penilaian kerentanan keamanan yang dirancang secara terbuka dan terstandarisasi.



# TESTING FRAMEWORK



# RINGKASAN TEMUAN



| No | Nama Temuan                                                     | Tingkat Keparahan | Status |
|----|-----------------------------------------------------------------|-------------------|--------|
| 1  | SQL Injection                                                   | Critical          | Open   |
| 2  | Cross Site Scripting (XSS) - Stored                             | High              | Open   |
| 3  | Directory Listing                                               | High              | Open   |
| 4  | Security Misconfiguration                                       | Medium            | Open   |
| 5  | Security Misconfiguration                                       | Medium            | Open   |
| 6  | Security Misconfiguration                                       | Medium            | Open   |
| 7  | Unrestricted File Upload to Cross Site Scripting (XSS) - Stored | Medium            | Open   |



# CRITICAL: SQL INJECTION

*Terdapat SQL Injection pada halaman login yang memungkinkan penyerang masuk tanpa kredensial valid dan mendapatkan akses admin.*

## LOKASI

<https://lab.codelamp.my.id/login.php>

## DAMPAK

- Bypass Otentikasi, Penyerang dapat login sebagai admin
- Kompromi Data Sensitif, Data dapat dibaca, diubah atau dihapus
- Integritas dan Ketersediaan, potensi merusak atau penghapusan database

## REKOMENDASI

- Gunakan **prepared statements**
- Lakukan **validasi & sanitasi input**
- Terapkan **least privilege** untuk akun database

# POC: SQL INJECTION

*Terdapat SQL Injection pada halaman login yang memungkinkan penyerang masuk tanpa kredensial valid dan mendapatkan akses admin.*

JerseySekaT

Login

Username

'OR+1=1--'

Password

Login

© 2025 JerseySekaT - Lab Keamanan Siber

JerseySekaT

Profil Pengguna

Halo, **admin**. Selamat datang di halaman profil Anda.

Unggah Foto Profil

Pilih foto profil baru

Browse...

No file selected.

Hanya file .jpg, .png, .gif yang diizinkan.

Unggah

© 2025 JerseySekaT - Lab Keamanan Siber

# HIGH: STORED XSS

*Terdapat vulnerability Stored XSS pada kolom ulasan, payload seperti `<script>alert(1)</script>` dapat dieksekusi di browser.*

## LOKASI

<https://lab.codelamp.my.id/product.php?id=1>

## DAMPAK

- Session hijacking
- Pencurian data sensitif
- Defacement
- Redirect ke situs berbahaya

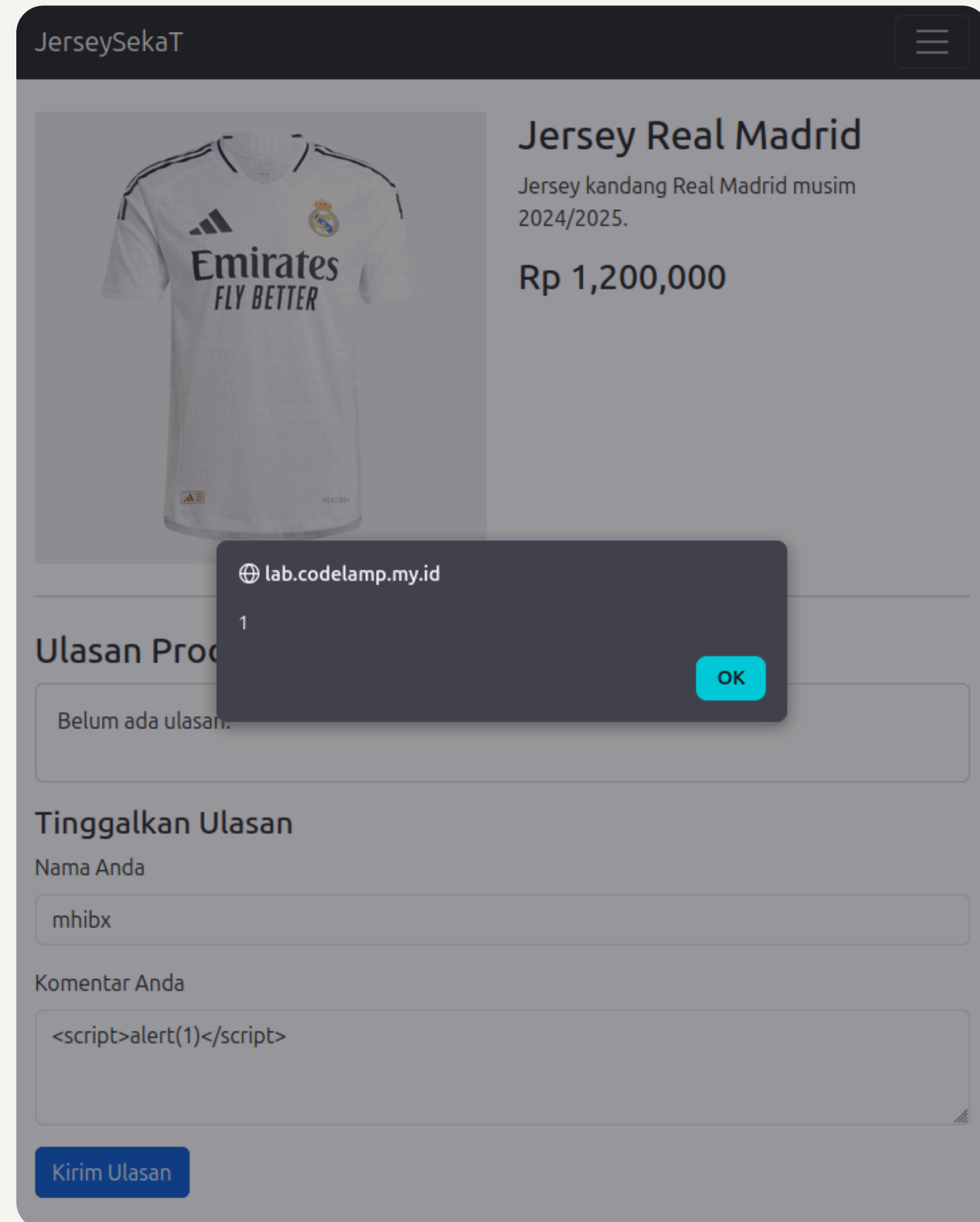
## REKOMENDASI

- **Validasi dan sanitasi** input, blokir tag HTML atau karakter berbahaya
- Terapkan **output encoding** pada data sebelum ditampilkan



# POC: STORED XSS

*Terdapat vulnerability Stored XSS pada kolom ulasan, payload seperti `<script>alert(1)</script>` dapat dieksekusi di browser.*



# HIGH: DIRECTORY LISTING

*Direktori **/uploads** dapat diakses publik dan menampilkan seluruh file yang diunggah.*

## LOKASI

<https://lab.codelamp.my.id/uploads>

## DAMPAK

- Pengungkapan file dan informasi sensitif
- Mempermudah serangan lanjutan
- Berpotensi naik ke **critical** bila file berbahaya dieksekusi

## REKOMENDASI

- **Nonaktifkan** directory indexing
- tambahkan **index.html** kosong sebagai fallback

# POC: DIRECTORY LISTING

Direktori */uploads* dapat diakses publik dan menampilkan seluruh file yang diunggah.

```
mhw@mhw-ubuntu:~$ dirsearch -u https://lab.codelamp.my.id/ -i 200,301,302
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources
is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _ _ _ _ _ _ _ _ _ _ v0.4.3
  ( _ _ _ _ ) ( _ _ _ _ )

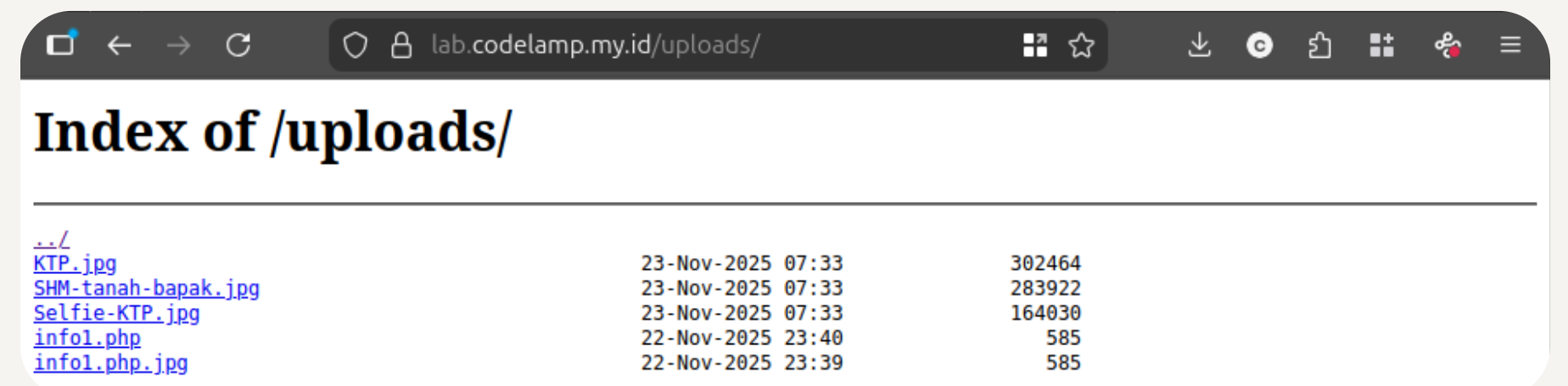
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25
Wordlist size: 11460

Output File: /home/mhw/reports/https_lab.codelamp.my.id/__25-11-23_14-06-44.txt

Target: https://lab.codelamp.my.id/

[14:06:44] Starting:
[14:06:46] 200 - 8KB - /.DS_Store
[14:06:52] 301 - 169B - /admin -> http://lab.codelamp.my.id/admin/
[14:07:13] 301 - 169B - /includes -> http://lab.codelamp.my.id/includes/
[14:07:16] 200 - 2KB - /login.php
[14:07:17] 302 - 0B - /logout.php -> index.php
[14:07:28] 200 - 2KB - /product.php
[14:07:28] 200 - 3KB - /profile.php
[14:07:30] 200 - 3KB - /register.php
[14:07:31] 200 - 96B - /robots.txt
[14:07:32] 200 - 2KB - /search.php
[14:07:43] 200 - 383B - /uploads/
[14:07:43] 301 - 169B - /uploads -> http://lab.codelamp.my.id/uploads/

Task Completed
```



| Index of /uploads/                  |                   |        |
|-------------------------------------|-------------------|--------|
| ../                                 |                   |        |
| <a href="#">KTP.jpg</a>             | 23-Nov-2025 07:33 | 302464 |
| <a href="#">SHM-tanah-bapak.jpg</a> | 23-Nov-2025 07:33 | 283922 |
| <a href="#">Selfie-KTP.jpg</a>      | 23-Nov-2025 07:33 | 164030 |
| <a href="#">info1.php</a>           | 22-Nov-2025 23:40 | 585    |
| <a href="#">info1.php.jpg</a>       | 22-Nov-2025 23:39 | 585    |

## MEDIUM: SECURITY MISCONFIG 1

*Direktori **/robots.txt** mengungkapkan direktori sensitif **/admin/**, sehingga membuka informasi internal yang seharusnya tidak ditampilkan.*

### LOKASI

<https://lab.codelamp.my.id/robots.txt>

### DAMPAK

- Penyerang dapat melakukan **bruteforce** untuk mencoba akses ke **/admin/**
- Memudahkan pencarian vulnerability di halaman admin (default credentials, directory listing, dll)

### REKOMENDASI

- Hapus direktori sensitif seperti **/admin/** dari robots.txt.

# POC: SECURITY MISCONFIG 1

*Direktori **/robots.txt** mengungkapkan direktori sensitif **/admin/**, sehingga membuka informasi internal yang seharusnya tidak ditampilkan.*

```
mhw@mhw-ubuntu:~$ dirsearch -u https://lab.codelamp.my.id/ -i 200,301,302
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources
is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _I_ _ _ _ _I_ v0.4.3
  (III) (/ _ (II (I)

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25
Wordlist size: 11460

Output File: /home/mhw/reports/https_lab.codelamp.my.id/__25-11-23_14-06-44.txt

Target: https://lab.codelamp.my.id/

[14:06:44] Starting:
[14:06:46] 200 - 8KB - /.DS_Store
[14:06:52] 301 - 169B - /admin -> http://lab.codelamp.my.id/admin/
[14:07:13] 301 - 169B - /includes -> http://lab.codelamp.my.id/includes/
[14:07:16] 200 - 2KB - /login.php
[14:07:17] 302 - 0B - /logout.php -> index.php
[14:07:28] 200 - 2KB - /product.php
[14:07:28] 200 - 3KB - /profile.php
[14:07:30] 200 - 3KB - /register.php
[14:07:31] 200 - 96B - /robots.txt
[14:07:32] 200 - 2KB - /search.php
[14:07:43] 200 - 383B - /uploads/
[14:07:43] 301 - 169B - /uploads -> http://lab.codelamp.my.id/uploads/

Task Completed
```

```
lab.codelamp.my.id/robots.txt

User-agent: *
# Kami tidak ingin Google meng-index halaman admin rahasia kami
Disallow: /admin/
```



## MEDIUM: SECURITY MISCONFIG 2

*Hanya 1 dari 11 secure header yang aktif pada aplikasi. Ini berarti banyak mekanisme keamanan browser tidak berfungsi, sehingga meningkatkan risiko serangan sisi-klien.*

### LOKASI

<https://lab.codelamp.my.id/>

### DAMPAK

- Tanpa CSP → risiko XSS meningkat.
- Tanpa X-Frame-Options → rentan Clickjacking.
- Tanpa HSTS → rentan Man-in-the-Middle.
- Tanpa X-Content-Type-Options → risiko MIME sniffing.

### REKOMENDASI

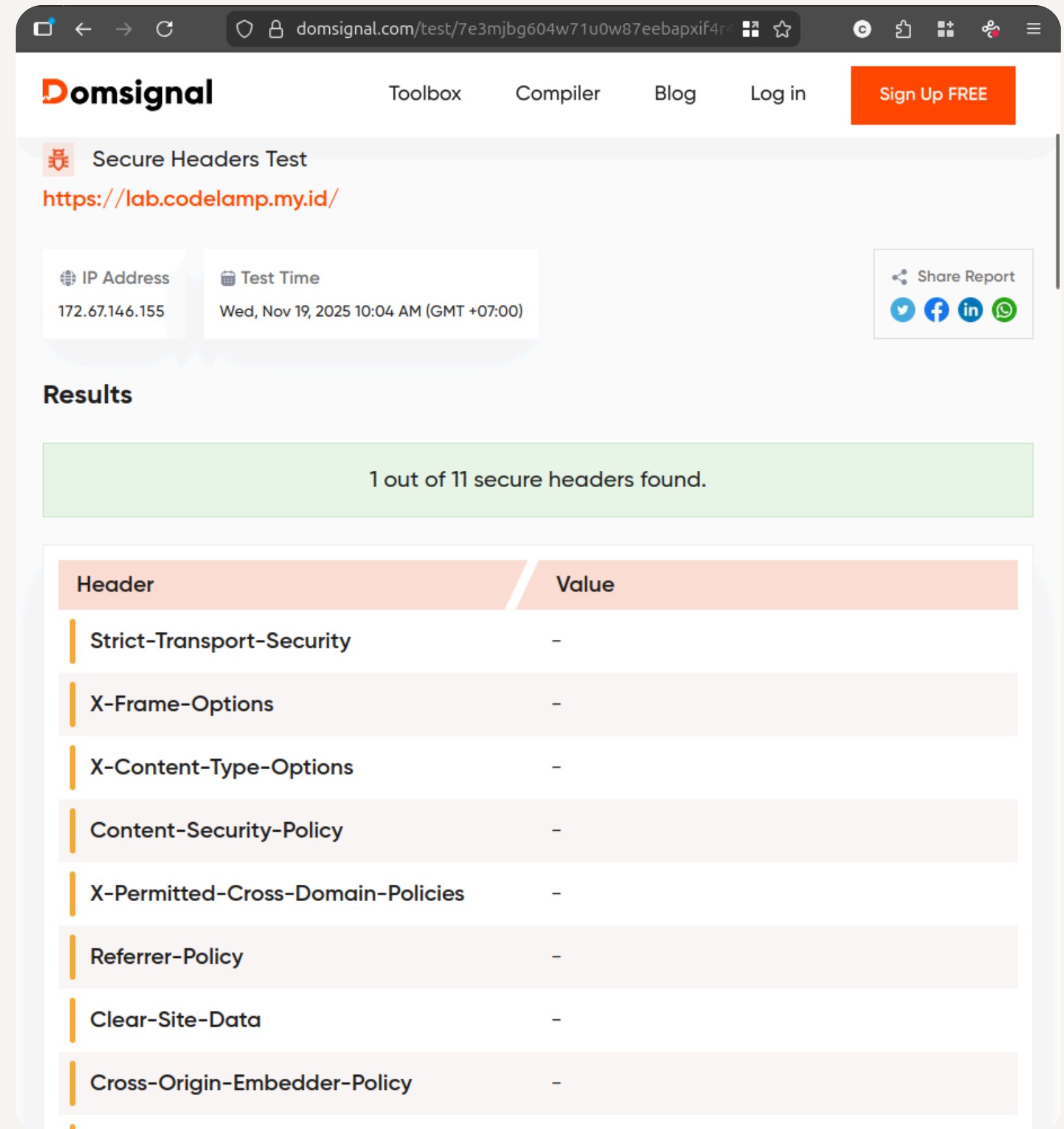
Aktifkan seluruh secure headers penting, termasuk:

CSP, HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Cache-Control, COEP, COOP, CORP, Clear-Site-Data, X-Permitted-Cross-Domain-Policies.



# POC: SECURITY MISCONFIG 2

*Hanya 1 dari 11 secure header yang aktif pada aplikasi. Ini berarti banyak mekanisme keamanan browser tidak berfungsi, sehingga meningkatkan risiko serangan sisi-klien.*



The screenshot shows the Domsignal website's Secure Headers Test interface. The URL being tested is <https://lab.codelamp.my.id/>. The test results show that only 1 out of 11 secure headers is found. The table below lists the headers and their values.

| Header                            | Value |
|-----------------------------------|-------|
| Strict-Transport-Security         | -     |
| X-Frame-Options                   | -     |
| X-Content-Type-Options            | -     |
| Content-Security-Policy           | -     |
| X-Permitted-Cross-Domain-Policies | -     |
| Referrer-Policy                   | -     |
| Clear-Site-Data                   | -     |
| Cross-Origin-Embedder-Policy      | -     |

## MEDIUM: SECURITY MISCONFIG 3

*File **.DS\_Store** dapat diakses secara publik. Meski berasal dari sistem macOS, file ini tetap dapat mengungkapkan struktur direktori dan metadata internal.*

### LOKASI

[https://lab.codelamp.my.id/.DS\\_Store](https://lab.codelamp.my.id/.DS_Store)

### DAMPAK

- Mengungkap informasi direktori yang membantu reconnaissance.
- Memberikan gambaran struktur file yang tidak seharusnya diketahui penyerang.

### REKOMENDASI

- Blok akses file tersembunyi (.\* ) pada web server.
- Tambahkan .DS\_Store ke .gitignore.
- Hapus file .DS\_Store dari direktori publik di server.



# POC: SECURITY MISCONFIG 3

*File **.DS\_Store** dapat diakses secara publik. Meski berasal dari sistem macOS, file ini tetap dapat mengungkapkan struktur direktori dan metadata internal.*

```
mhw@mhw-ubuntu:~$ dirsearch -u https://lab.codelamp.my.id/ -i 200,301,302
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources
is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _l_ _ _ _ _l_ v0.4.3
  (III) (/_II (I)

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25
Wordlist size: 11460

Output File: /home/mhw/reports/https_lab.codelamp.my.id/__25-11-23_14-06-44.txt

Target: https://lab.codelamp.my.id/

[14:06:44] Starting:
[14:06:46] 200 - 8KB - /.DS_Store
[14:06:52] 301 - 169B - /admin -> http://lab.codelamp.my.id/admin/
[14:07:13] 301 - 169B - /includes -> http://lab.codelamp.my.id/includes/
[14:07:16] 200 - 2KB - /login.php
[14:07:17] 302 - 0B - /logout.php -> index.php
[14:07:28] 200 - 2KB - /product.php
[14:07:28] 200 - 3KB - /profile.php
[14:07:30] 200 - 3KB - /register.php
[14:07:31] 200 - 96B - /robots.txt
[14:07:32] 200 - 2KB - /search.php
[14:07:43] 200 - 383B - /uploads/
[14:07:43] 301 - 169B - /uploads -> http://lab.codelamp.my.id/uploads/

Task Completed
```

```
mhw@mhw-ubuntu:~/Documents/tugas/bootcamp/codelamp/exam$ strings Untitled.DS_Store
Bud1
sbwspbl
sbwspblob
bplist00
]ShowStatusBar[ShowToolBar[ShowTabView_
ContainerShowSidebar\WindowBounds[ShowSidebar
```

## MEDIUM: UNRESTRICTED FILE UPLOAD TO XSS-STORED

*Aplikasi tidak memvalidasi jenis file dengan benar. File ber-ekstensi valid dapat di-upload, lalu ekstensi diubah melalui Burpsuite sehingga file HTML berisi payload XSS berhasil disimpan dan dijalankan (stored XSS).*

## LOKASI

<https://lab.codelamp.my.id/uploads>

## DAMPAK

- File berbahaya dapat diunggah dan diakses publik.
- Stored XSS memungkinkan:
  - Pencurian sesi (session hijacking)
  - Pencurian data sensitif
  - Pengubahan tampilan (defacement)
  - Redirect atau penyebaran malware

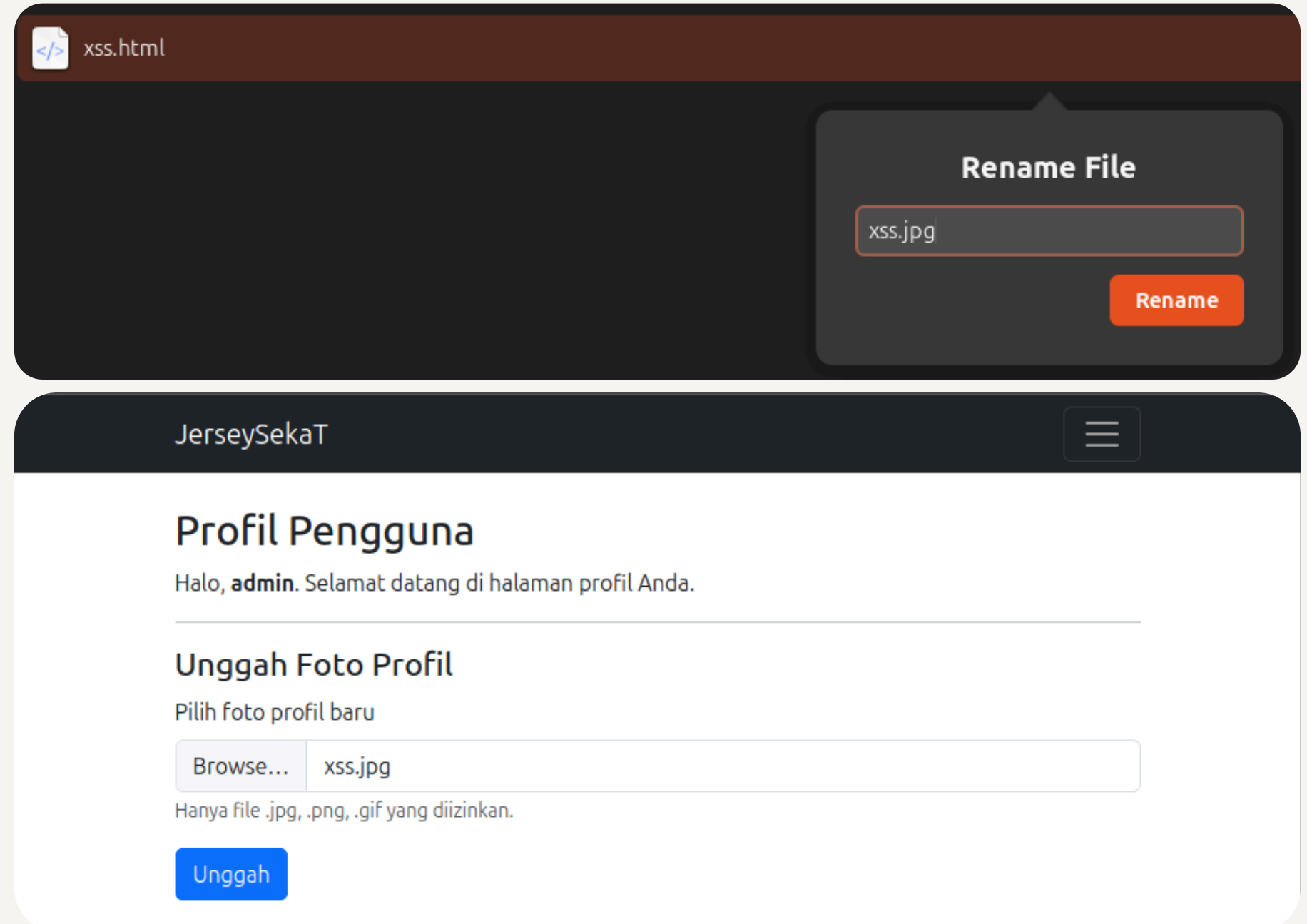
## REKOMENDASI

- Lakukan content inspection (periksa isi file, bukan hanya ekstensi).
- Simpan file ke direktori non-eksekusi.
- Batasi izin file system agar tidak dapat dieksekusi.
- Ubah nama file menjadi acak dan aman.

# POC: UNRESTRICTED FILE UPLOAD TO XSS-STORED

*Aplikasi tidak memvalidasi jenis file dengan benar. File ber-ekstensi valid dapat di-upload, lalu ekstensi diubah melalui Burpsuite sehingga file HTML berisi payload XSS berhasil disimpan dan dijalankan (stored XSS).*

```
mhw@mhw-ubuntu:~/Documents/tugas/bootcamp/codelamp/exam$ cat xss.html
<html>
<head></head>
<body>
<img src=1 href=1 onerror="javascript:alert(1)"></img>
</body>
</html>
```



## POC 2: UNRESTRICTED FILE UPLOAD TO XSS-STORED

*Aplikasi tidak memvalidasi jenis file dengan benar. File ber-ekstensi valid dapat di-upload, lalu ekstensi diubah melalui Burpsuite sehingga file HTML berisi payload XSS berhasil disimpan dan dijalankan (stored XSS).*

The image displays a Proof of Concept (POC) for a stored XSS vulnerability in a web application. It is divided into three main sections:

- Request:** A network request captured by Burp Suite. The 'Content-Disposition' header is highlighted with a red box, showing it is set to 'form-data; name="fileToUpload"; filename="xss.html"'. The body of the request contains an HTML payload: `<img src=1 href=1 onerror="javascript:alert(1)"></img>`.
- Web Interface:** A screenshot of the 'JerseySekaT' user profile page. It shows a message: 'File xss.html berhasil diunggah. [Lihat file](#)' (File xss.html successfully uploaded. View file).
- Browser:** A screenshot of a web browser showing an alert box with the text '1' and an 'OK' button, indicating the successful execution of the JavaScript payload.

## PENUTUP KESIMPULAN

PT Mini Bootcamp Sukses telah menyelesaikan kegiatan Penetration Testing dengan dukungan penuh dari tim IT klien. Beberapa kelemahan keamanan berhasil diidentifikasi dan perlu segera diperbaiki sesuai rekomendasi pada laporan ini agar meningkatkan keamanan aplikasi ke depannya.

Kami menyarankan Penetration Testing dilakukan setidaknya sekali dalam setahun, sesuai standar internasional dan ISO 27001, untuk menjaga postur keamanan dan mencegah serangan siber yang berkembang.

